Portafolio de seguridad — Belona Cybersecurity

Belona Cybersecurity LLC · Powder Springs, Georgia belonacyber.com · contact@belonacyber.com

> **Sobre la anonimización.** Los trabajos aquí documentados son reales y se realizaron con autorización del propietario. El nombre del cliente y los identificadores de su infraestructura se reemplazaron por marcadores (`Cliente A` , `cliente-a`) antes de publicarlos. **Belona Cybersecurity no publica datos identificables de un cliente sin su autorización por escrito** — la misma regla que aplicamos a cada encargo.

Security engineering work hardening a **production legal-services web platform** on **Firebase / Google Cloud**, performed end to end as the sole technical owner: authentication, authorization, penetration testing with remediation, backups/DR, detection & monitoring, threat modeling, and data-protection compliance — applying **DevSecOps practices** (security-as-code, CI security gates) throughout.

> **Start here:** Case Study — DevSecOps — a 2-minute executive summary of the whole engagement.


Security architecture diagram

Defense-in-depth architecture — a shift-left CI/CD pipeline, runtime prevention, detection, response and recovery, mapped to NIST CSF.

Impact summary

Area	What was delivered
Authentication	MFA/TOTP on the admin panel (resolved a session-timing enrollment blocker)
Authorization	Role-based access control (admin / lawyer / editor) enforced by Firestore & Storage security rules
Pentest	3-phase authorized test; found & remediated a **critical** `.git` + GitHub-token exposure served by Hosting
Abuse prevention	App Check + server-side rate limiting on the contact form
Hardening	Content-Security-Policy allow-list, security headers, secrets migrated to Google Secret Manager
Recovery	3-2-1 backups: PITR (7d) + daily backups (14d) + object versioning + offsite weekly export
Detection	File Integrity Monitoring (SHA-256, every 6h) + Cloud Monitoring log alerts + Dependabot / `npm audit` CI gate
Compliance	Consent capture + proof; privacy-policy international-transfer clause (Colombia's Law 1581, analogous to GDPR/CCPA)

Result: full **AAA** coverage (Authentication, Authorization, Accounting) and defense in depth across prevention / detection / recovery — with **no added third-party attack surface** and **no added recurring cost**.

Documents (English)

#	Document	What it covers
1	Case Study — DevSecOps	Executive overview of the full engagement (**read this first**)
2	Penetration Test Report	Recon, authz testing, privilege-escalation attempts, findings & remediation
3	PASTA Threat Model (stages 3–7)	Decomposition, threats, CWE/OWASP mapping, attack trees, residual-risk matrix
4	**Recovery capability: from "we have backups" to "we can restore"**	RPO/RTO, 3-2-1, and **a control documented as implemented that wasn't** — found by going to test the restore
5	**Email authentication: SPF, DKIM & DMARC**	Staged rollout (`none` → `quarantine` → `reject`), reading the first DMARC report, and a DNS migration with **zero mail downtime**
6	**Hardening a contact form against abuse**	Eight layers on a Cloudflare Worker — captcha verified server-side, honeypot, secrets off disk — **each one exercised with `curl` in production**
7	Incident Response Playbooks	5 NIST-based playbooks (breach, defacement, data loss, account compromise, DoS)
8	Security Awareness Training	7 modules mapped to CIS Control 14 / NIST CSF PR.AT

Each document is also available in Markdown (`.md`) next to the PDF. See `english/` for the full set.

Las versiones en español están en la raíz del repositorio. Cada documento existe en los dos idiomas, salvo el caso de estudio inicial.

Tech stack

Cloud: Firebase (Hosting, Authentication / Identity Platform, Firestore, Storage, Cloud Functions), Google Cloud Platform, App Check, Secret Manager, Cloud Monitoring, Cloud Scheduler. **Security:** IAM / RBAC (custom claims), security rules as code, MFA/TOTP, Content-Security-Policy, penetration testing (nmap), File Integrity Monitoring (Python + GitHub Actions), Dependabot, PASTA threat modeling, NIST incident response.

Skills demonstrated

Cloud security (GCP/Firebase) · IAM & RBAC · security rules as code · penetration testing & remediation · secrets management · backup / disaster recovery (3-2-1, RPO/RTO) · detection engineering (FIM, log-based

alerting) · supply-chain security · threat modeling (PASTA) · incident response (NIST) · security awareness · data-protection compliance (Law 1581 / GDPR-style).

Plataforma en producción: sitio público + panel de administración de una firma legal. Work performed by the sole technical owner as a self-directed cloud security portfolio project. Sensitive values (keys, tokens, client data) are intentionally excluded from this repository.
